

Risk_ID	Asset	Scenario	Category
---------	-------	----------	----------

GOVERNANCE(GOV)

GOV-01	Board Governance	Policy noncompliance due to lack of annual review	GOV
--------	------------------	---	-----

COMPLIANCE(CMP)

CMP-01	Vendor SaaS Platform	Failure to maintain SOC 2 compliance	CMP
CMP-02	Customer Data	Unencrypted data transfer violating HIPAA	CMP

OPERATIONS(OPS)

OPS-01	Local NAS	Hardware failure leading to data loss	OPS
OPS-02	Cloud Billing API	Outage due to code deployment error	OPS

SECURITY(SEC)

SEC-01	User Email Accounts	Phishing attack leading to credential compromise	SEC
SEC-02	AWS EC2 Web App	Ransomware attack on application host	SEC
SEC-03	Office Wi-Fi Network	Unauthorized access via weak WPA2 password	SEC

Likelihood	Impact	Status	Lambda_Min	Lambda_Mode	Lambda_Max	Loss_Min
------------	--------	--------	------------	-------------	------------	----------

Medium	Medium	Open	0.1	0.2	0.4	10000
--------	--------	------	-----	-----	-----	-------

Low	High	Open	0.05	0.1	0.3	25000
Very Low	High	Open	0.05	0.1	0.2	25000

Medium	High	Mitigated	0.1	0.3	0.5	15000
High	Medium	Accepted	0.3	0.4	0.6	20000

High	High	Open	0.3	0.5	0.8	30000
Medium	Critical	Open	0.1	0.2	0.4	50000
Low	Medium	Mitigated	0.05	0.1	0.2	10000

Loss_Mode	Loss_Max	Owner	Notes
-----------	----------	-------	-------

25000	50000	Compliance Officer	Policy review overdue; new governance calendar in draft
-------	-------	--------------------	---

60000	120000	Risk Manager	SOC 2 audit in progress; corrective actions tracked
80000	150000	Compliance Officer	Encryption at rest complete; in-transit TLS audit pending

50000	100000	IT Manager	Backups automated to AWS S3; tested quarterly
40000	80000	DevOps Lead	Risk accepted pending DevOps pipeline upgrade

70000	150000	Security Analyst	MFA enforced; phishing simulation planned Q1
150000	250000	CISO	EDR enabled; immutable backups in progress
20000	50000	IT Support	Upgraded to WPA3; password rotation enforced

Risk Description	Regulatory Impact	Risk Rating
------------------	-------------------	-------------

Policy noncompliance due to lack of annual review	N/A	Medium
---	-----	--------

Failure to maintain SOC 2 compliance	SOC 2	High
Unencrypted data transfer violating HIPAA	HIPAA	Medium

Hardware failure leading to data loss	N/A	High
Outage due to code deployment error	N/A	High

Phishing attack leading to credential compromise	N/A	Critical
Ransomware attack on application host	HIPAA (potential breach notification)	Critical
Unauthorized access via weak WPA2 password	N/A	Medium

Mitigation/Control

Governance calendar drafted; annual policy review schedule being implemented
--

External SOC 2 audit underway; CAPs tracked to closure
--

TLS in-transit audit scheduled; M365 DLP tuning

Automated S3 backups; quarterly restore tests

Change management hardening planned; canary deploys pending

MFA enforced; user training and phishing simulations scheduled
--

EDR deployed; immutable backups and recovery runbooks in progress

WPA3 enabled; credential rotation and guest VLAN segregation
--

